

ProofLayer: Automated Cybersecurity Compliance Auditing for State Government Policies via Multi-LLM Orchestration

Devharsh Trivedi

Bowie State University, MD, USA

dtrivedi@bowiestate.edu ORCID: 0000-0001-6374-7249

Abstract

Cybersecurity compliance auditing for state and local government agencies remains a labor-intensive and expensive process, often requiring months of expert effort to assess policy documents against frameworks such as FedRAMP, NIST SP 800-53 Rev 5, and the Cybersecurity Maturity Model Certification (CMMC). This paper reports a keyword-based compliance mapping study of ten Maryland state and local government cybersecurity policy documents, spanning risk management, network security, incident response, and acceptable-use policies, and describes the architecture of ProofLayer, a compliance auditing engine built around it. Mapping 22 ProofLayer controls across 13 NIST SP 800-53 control families gives a mean coverage score of 49.1% across the corpus, with nine of ten documents rated high or medium risk. Systemic gaps appear in account management (AC-02, absent in 9 of 10 documents), data encryption at rest (SC-02, absent in 9 of 10), access control policy (AC-01, absent in 8 of 10), and incident reporting (IR-02, absent in 8 of 10). We further describe, but do not evaluate, two components of the wider system: an LLM-based gap analysis stage, and a cost-aware routing layer that directs lower-cost models to extraction tasks and stronger models to reasoning tasks. A published-price cost model projects a 24% reduction in per-audit inference cost for that routing strategy relative to using a single high-capability model throughout; this is an arithmetic projection from vendor rates, not a measured result. The evaluated contribution is therefore the keyword mapping and the gap profile it yields for Maryland’s policy corpus, which identifies concrete remediation priorities; the LLM reasoning stage and its accuracy remain open questions, and we set out the annotation protocol that would settle them.

Keywords: cybersecurity compliance auditing, government policy analysis, NIST SP 800-53, large language models, control gap analysis

1 Introduction

State and local governments are increasingly targeted by sophisticated cyberattacks. Between 2022 and 2025, over 1,800 reported breaches affected public and private organizations in the United States, with ransomware attacks on Baltimore City costing an estimated \$18 million and similar incidents shutting down services across Maryland school systems and healthcare networks [1]. Despite growing awareness of these threats, a 2021 analysis by the Maryland Cybersecurity Council found that 53.8% of local emergency management offices lacked a consequence management plan, and only 31% of local school systems reported adequate cybersecurity budget allocations [2].

Federal compliance frameworks such as NIST Special Publication 800-53 Revision 5 [3], the Federal Risk and Authorization Management Program (FedRAMP) [4], and the Cybersecurity Maturity Model Certification (CMMC) [5] provide structured sets of security controls for assessing organizational cybersecurity posture. However, mapping government policy documents to these frameworks manually is prohibitively expensive: independent assessments for FedRAMP authorization can cost between \$50,000 and \$500,000 and take 6–18 months to complete [4]. This cost burden falls disproportionately on smaller agencies and municipalities that have limited IT security budgets.

Recent advances in large language models (LLMs) open a new possibility: automating the reading, interpretation, and gap analysis of free-text policy documents against structured control frameworks. Prior work has demonstrated LLM applicability to legal compliance analysis [6], post-incident policy gap detection [7], multi-framework regulatory gap detection [8], and compliance automation in financial services [9]. However, no prior work has applied LLM-based compliance auditing specifically to state and local government cybersecurity policy documents at scale, nor has the cost efficiency of a multi-LLM routing strategy been evaluated in this domain.

This paper makes one evaluated contribution and two descriptive ones, and we distinguish them explicitly because only the first rests on measurement.

1. **Evaluated.** An **empirical keyword-based compliance mapping** of ten Maryland state and local government cybersecurity policy documents against 22 controls drawn from 13 NIST SP 800-53 families, reporting a mean coverage of 49.1% and revealing systemic gaps in encryption at rest, account management, and incident reporting that cut across agency types. This is the result the paper stands on.
2. **Described, not evaluated.** The design and implementation of **ProofLayer**, a compliance auditing pipeline that ingests policy documents and produces structured audit reports. Its second stage applies an LLM to gap analysis and remediation guidance. That stage is implemented and specified here, but it has not been evaluated against expert annotation, so no accuracy claim is made for it. Section 6.2 states the annotation protocol that would settle the question.
3. **Projected, not measured.** A **cost-aware multi-LLM routing strategy** that directs cheaper models to extraction and stronger models to reasoning. An arithmetic model over published vendor rates projects roughly 24% lower per-audit inference cost than using a single high-capability model throughout. This is a projection from list prices, not an observed saving, and it inherits whatever error the underlying token estimates carry.

Separating these matters for how the paper should be read. A two-stage system whose second stage is unevaluated is, evidentially, a one-stage study with an architecture proposal attached, and we present it as such rather than letting the system diagram carry an implied claim.

The remainder of this paper is organized as follows. Section 2 reviews related work. Section 3 describes the ProofLayer system architecture. Section 4 presents our methodology. Section 5 reports experimental results on the Maryland policy corpus. Section 6 discusses findings and limitations. Section 7 concludes.

2 Background and Related Work

This section provides the context needed to situate ProofLayer within existing work. We first survey the federal and state cybersecurity compliance frameworks against which policy documents are audited, then review recent applications of LLMs to regulatory and compliance analysis, and finally examine the emerging literature on multi-LLM orchestration for cost-aware AI pipelines.

2.1 Cybersecurity Compliance Frameworks

NIST SP 800-53 Rev 5 [3] is the canonical reference for federal information system security controls, defining over 1,000 security controls and control enhancements across 20 families covering areas from access control (AC) and audit accountability (AU) to system and communications protection (SC). FedRAMP builds on NIST 800-53 to specify cloud security requirements for federal agency cloud services [4]. CMMC extends this framework to DoD supply chain contractors, defining three maturity levels comprising 110 practices mapped from NIST SP 800-171 [5].

Maryland has aligned its state Minimum Cybersecurity Standards to the NIST Cybersecurity Framework [10], and since 2022 has required all units of local government to certify compliance with state minimum standards under SB754 of 2022 [2]. Nevertheless, the 2021 Maryland Cybersecurity Council analysis found wide variation in policy coverage and implementation across agencies, particularly at the local government level.

2.2 LLMs for Compliance and Regulatory Analysis

The intersection of natural language processing and regulatory compliance has been an active research area. Early work used rule-based and classical machine learning methods to extract compliance obligations from regulatory text [8]. More recently, LLMs have shown strong performance on compliance-related tasks including legal document interpretation, privacy policy analysis, and policy gap detection [11]. Salman et al. [12] specifically examine LLMs for cybersecurity compliance, showing that continuous LLM-based monitoring can reduce reliance on expensive periodic audits.

Hassani et al. [6] argue that LLMs enable a shift from sentence-level classification to end-to-end compliance reasoning, addressing a key limitation of prior NLP approaches that processed policy text in isolated fragments. Their work on legal compliance automation at the IEEE Requirements Engineering conference provides a framework for thinking about how LLMs can handle the full context of a regulatory document. Independently, the “Automated Post-Incident Policy Gap Analysis” system by Oh et al. [7] demonstrates an LLM-driven multi-agent workflow that maps system event log evidence to MITRE ATT&CK entries and then evaluates organizational policies for adequacy, using GPT-4o and LangGraph. ComplianceNLP [8] combines knowledge-graph-augmented retrieval-augmented generation (RAG) with multi-task obligation extraction to achieve 87.7 F1 on gap detection across SEC, MiFID II, and Basel III regulatory frameworks, outperforming GPT-4o+RAG baselines by 3.5 F1 points.

Our work differs from the above in three ways: (i) we target government cybersecurity policy documents rather than financial regulations; (ii) we apply keyword-based Stage 1 mapping as a no-API-cost baseline before engaging LLM reasoning; and (iii) we evaluate the cost efficiency of multi-model routing, a concern that prior work has not addressed in the compliance context.

2.3 Multi-LLM Orchestration

The idea of routing tasks to different LLMs based on complexity and cost is an emerging research direction. xRouter [13] trains a reinforcement learning router that routes requests to cost-appropriate models under explicit economic constraints, achieving strong Pareto-optimal operating points on cost-accuracy tradeoffs. Benchmarking by Kulkarni and Kulkarni [14] compares sequential, parallel, hierarchical, and reflexive multi-agent architectures for financial document processing, finding that reflexive architectures achieve

the highest field-level accuracy but at $2.3\times$ the cost of sequential baselines. ProofLayer applies analogous routing principles to the compliance auditing domain: lightweight models for pattern recognition and text extraction, stronger models for reasoning-intensive gap analysis and report generation.

3 System Architecture

Figure 1 illustrates the ProofLayer architecture, which consists of five components: a document ingestion layer, an AI extraction module, a control mapping engine, a multi-LLM orchestration layer, and an output generation module.

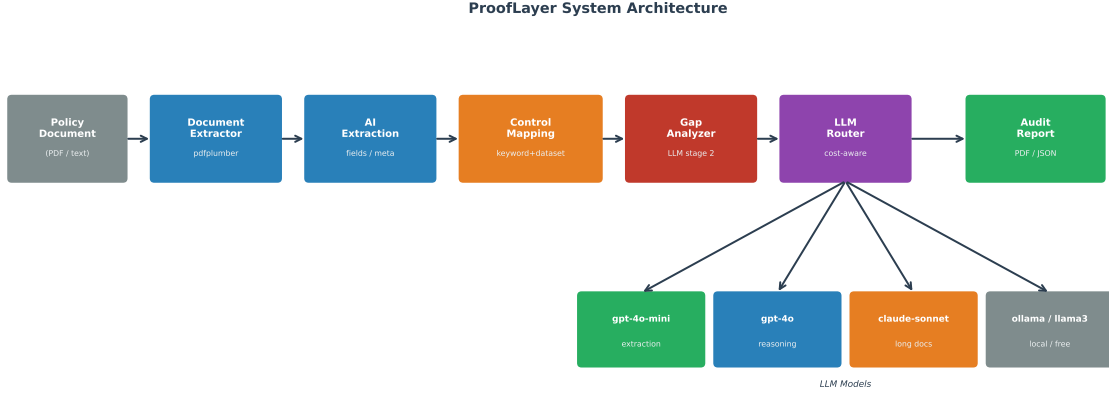


Figure 1: ProofLayer system architecture. Policy documents enter through the ingestion layer, are processed by a two-stage compliance mapping pipeline, and routed to cost-appropriate LLMs for gap analysis and report generation. Source: generated by the authors from the analysis pipeline described in Section 4.1.

3.1 Document Ingestion

ProofLayer accepts policy documents in PDF or plain text format. PDF text is extracted using pdfplumber [15], which handles multi-column layouts common in government documents. Extracted text is stored in memory with a unique document ID for subsequent processing. Documents exceeding 15,000 characters are flagged for routing to `claude-sonnet`, which offers strong long-context performance at competitive cost relative to token count. Character count serves as a practical proxy for token count (approximately 4 characters per English token); at this threshold a document’s content occupies roughly 3,750 tokens, which approaches the practical input budget available to `gpt-4o` after accounting for prompt template overhead, making the larger effective context window of `claude-sonnet` beneficial for full-document coverage.

3.2 AI Extraction

An optional AI extraction pass uses `gpt-4o-mini` to normalize and summarize security-relevant content from the raw document text, producing a condensed representation of security practices, policies, and procedures. This step costs approximately \$0.003 per document (under 2,000 input tokens) and reduces noise for downstream processing.

3.3 Control Mapping Engine

The control mapping engine is the analytical core of ProofLayer. It implements a deliberate two-stage pipeline that separates low-cost pattern recognition from high-cost contextual reasoning, allowing the system to scale economically to large document corpora while preserving analytical depth for controls that require it.

Stage 1 – Keyword Matching. Each document is scanned for occurrence of framework-specific keywords associated with each control in the dataset. This stage requires no LLM API calls, runs in under 50 milliseconds per document, and incurs zero LLM inference cost. Controls are marked as “present” if any of their associated keywords appear in the document text.

Stage 2 – LLM Gap Analysis. A structured prompt containing the document summary and the full control list is sent to a reasoning-capable LLM (GPT-4o by default, with optional routing to Claude Sonnet for long documents or Ollama/LLaMA-3 for free local operation). The model is asked to classify each control as *verified*, *partial*, or *missing* and to provide an explanatory note. The JSON response is parsed and merged with Stage 1 results.

3.4 Control Dataset

The ProofLayer control dataset contains 22 controls spanning 13 NIST SP 800-53 Rev 5 control families organized into ten category groupings, cross-referenced to their FedRAMP, CMMC 2.0, and SOC2 equivalents. Each control record includes a human-readable name, a set of associated keywords, the applicable framework mappings, a risk level (HIGH or MEDIUM), and a remediation recommendation. Table 1 summarizes the control families included.

Table 1: ProofLayer control dataset: categories and framework mappings.

Category	Control IDs	NIST 800-53 Family	Count
Access Control	AC-01 to AC-05	AC, IA	5
Configuration Mgmt.	CM-01, CM-02	CM	2
Audit & Accountability	AU-01, AU-02	AU	2
Incident Response	IR-01, IR-02	IR	2
Risk Assessment	RA-01, RA-02	RA	2
System & Comm. Prot.	SC-01 to SC-03	SC	3
Personnel Security	PS-01, PS-02	AT, PS	2
Contingency Planning	CP-01, CP-02	CP	2
Supply Chain	SR-01	SA, SR	1
Media Protection	MP-01	MP	1
Total			22

3.5 Multi-LLM Orchestration Layer

ProofLayer implements a cost-aware task routing strategy shown in Table 2. The routing decision is made per task type and optionally per content length, directing extraction and keyword-mapping tasks to inexpensive small models and reserving high-capability models for reasoning-intensive gap analysis and report generation. When internet connectivity is unavailable or API budget constraints are binding, the system falls back to a locally hosted Ollama/LLaMA-3 instance, ensuring that auditing capability remains fully functional in air-gapped or cost-constrained environments without any code changes.

Table 2: ProofLayer multi-LLM routing strategy.

Task	Model	Approx. Cost/1K tok.	Rationale
Doc. Extraction	<code>gpt-4o-mini</code>	\$0.00015	Fast, cheap
Keyword/Sem. Mapping	<code>gpt-4o-mini</code>	\$0.00015	Sufficient for matching
Gap Analysis	<code>gpt-4o</code>	\$0.005	Needs strong reasoning
Report Generation	<code>gpt-4o</code>	\$0.005	Structured output required
Long docs (>15K ch.)	<code>claude-sonnet</code>	\$0.003	Strong long-context
Offline/Free mode	<code>ollama/llama3</code>	\$0.000	Local, no API cost

3.6 Output Generation

ProofLayer generates three types of outputs: (i) a structured JSON audit result containing per-control status, framework scores, and gap details; (ii) an LLM-generated narrative executive summary suitable for submission to an ISSO or inspector general; and (iii) a downloadable PDF audit report produced using ReportLab [16], containing score summaries, framework breakdowns, gap tables, and remediation guidance. An API endpoint at `/fix` additionally generates full policy document language for missing controls on demand, enabling agencies to obtain draft policy text as a remediation starting point without requiring specialized compliance writing expertise.

4 Materials and Methods

This section describes the evaluation design used to assess ProofLayer on real Maryland government cybersecurity policy documents. We detail the composition of the document corpus, the keyword-based Stage 1 mapping procedure applied in this study, the compliance scoring formula, and the cost estimation approach used to compare multi-LLM routing against a single-model baseline.

4.1 Policy Document Corpus

We evaluate ProofLayer on ten Maryland government cybersecurity policy documents listed in Table 3. Documents were selected according to three criteria: (i) publicly available from official Maryland government sources, (ii) primary focus on cybersecurity or information security policy content, and (iii) coverage of a distinct agency type or function. To the best of our knowledge, no publicly available Maryland cybersecurity policy documents satisfying these criteria were excluded. The corpus spans major branches and agencies including executive branch IT policy (DoIT), judicial branch, education (MSDE), health (DHMH), and local government analysis (UMGC/Maryland Cybersecurity Council). The corpus represents publicly available Maryland policy documents and is not intended to be statistically representative of all government cybersecurity policies.

Relationship to prior work on the same jurisdiction. These ten documents are the cybersecurity-policy subset of a larger 51-document Maryland corpus assembled for an earlier study of document-level classification [17]. That study asked a different question at a different granularity: whether a given document is cybersecurity-relevant at all, evaluated against the six core functions of the NIST Cybersecurity Framework 2.0, comparing keyword matching to LLM-assisted classification. It found keyword matching to have high recall but poor precision at the document level. The present study takes the ten documents that survive that relevance filter and asks a control-level question instead: which of 22 specific NIST SP 800-53 controls each document addresses. The frameworks differ (CSF 2.0 against SP 800-53 Rev 5), the unit of analysis differs (document against document-control pair), and no result from the earlier study is restated here as new. We note the overlap explicitly because the corpora share a jurisdiction and provenance, and because the earlier finding that keyword matching is imprecise at the document level is part of why the present control-level results are framed as indicators of likely gaps rather than confirmed deficiencies.

Table 3: Maryland government cybersecurity policy document corpus.

Document Label	Document	Size (chars)
MD Risk Mgmt Policy	MD-POL-201-01 Cyber Risk Mgmt Policy (2026)	17,572
MD System & Network Security	MD-POL-207-01 System & Network Policy (2026)	11,110
MD Continuous Monitoring	MD Continuous Monitoring Policy (2026)	11,413
MD Cyber Council Report 2025	MD Cybersecurity Council Biennial Report (2025)	41,422
MD IT Security Manual	MD IT Security Manual (2019, amended)	26,527
MD Local Gov Cyber 2021	MD State & Local Gov Cybersecurity Analysis (2021)	36,953
MD Health Dept IT Security	MD DHMH IT Security Policy	35,017
MD Judicial Info Security	MD Judicial Branch Information Security Policy	44,567
MD MSDE AUP 2024	MD MSDE Acceptable Use Policy (2024)	33,774
MD Procurement Manual	MD Procurement Manual (Cyber-relevant sections)	24,399

4.2 Stage 1: Keyword-Based Compliance Mapping

For the empirical evaluation reported in this paper, we apply the Stage 1 keyword-based control mapping pipeline exclusively, since it provides a reproducible, deterministic baseline that requires no LLM API keys and enables full replication of results. The 22-control keyword dictionary was developed by the first author by mapping each control’s formal NIST definition and associated assessment procedures to domain-specific keyword phrases (e.g., “encryption at rest,” “disk encryption,” “aes,” “data at rest” for SC-02); each control maps to between 3 and 15 keywords. The full keyword dictionary is provided in the supplementary notebook. A control is marked as *present* if any associated keyword appears (case-insensitively) in the document text. Prompt lengths were estimated from representative policy documents in the corpus.

4.3 Scoring

To produce comparable, interpretable results across documents of varying length and scope, we assign each document a single compliance coverage score derived from the fraction of the 22 ProofLayer controls that are marked present. This score is then mapped to a risk tier consistent with NIST maturity guidance. The overall compliance coverage score for each document is computed as:

$$S = \left\lfloor \frac{|\text{matched controls}|}{|\text{total controls}|} \times 100 \right\rfloor \quad (1)$$

Documents are classified as **LOW** risk ($S \geq 80$), **MEDIUM** risk ($55 \leq S < 80$), or **HIGH** risk ($S < 55$) based on heuristic thresholds calibrated to approximate NIST maturity guidance; these specific percentage values are not prescribed by NIST SP 800-53 directly. The gap frequency for each control is the number of documents in which that control is absent, providing a measure of systemic weakness across the policy corpus.

4.4 Cost Estimation

LLM inference costs are estimated using published per-thousand-token pricing for each model as of mid-2025. For a standard audit (document extraction, keyword mapping, LLM gap analysis, and narrative report generation), we compare the ProofLayer multi-LLM strategy against a single-model baseline in which all tasks are routed to gpt-4o. Estimated input and output token counts are based on ProofLayer’s production prompt templates and typical policy document lengths (extraction: 2,000 input / 400 output tokens; mapping: 1,500 / 300; gap analysis: 3,000 / 700; report: 2,500 / 800; long-document routing via claude-sonnet: 6,700 / 1,000). These are model inputs, not measured values. Actual costs will vary proportionally with document length. The full keyword dictionary, routing algorithm, cost model, and analysis code are provided in the supplementary Jupyter notebook.

5 Experimental Results

We report the results of applying ProofLayer’s Stage 1 keyword-based compliance mapping to the ten-document Maryland policy corpus. Results are organized by analysis type: aggregate coverage scores, the per-document per-control coverage heatmap, a systemic gap analysis identifying controls most frequently absent across the corpus, and a cost analysis comparing the multi-LLM routing strategy against a single high-capability model baseline.

5.1 Overall Compliance Coverage

Figure 2 shows the compliance coverage scores for all ten Maryland policy documents. The mean score across the corpus is 49.1% (SD = 17.3%), substantially below the LOW-risk threshold of 80%. Eight of ten documents are rated HIGH or MEDIUM risk. The MD Judicial Information Security Policy achieves the highest score (86%), benefiting from broad coverage of access control, encryption, incident response, and training topics. The MD Procurement Manual scores lowest (22%), reflecting its focus on contracting procedures with minimal explicit security control discussion.

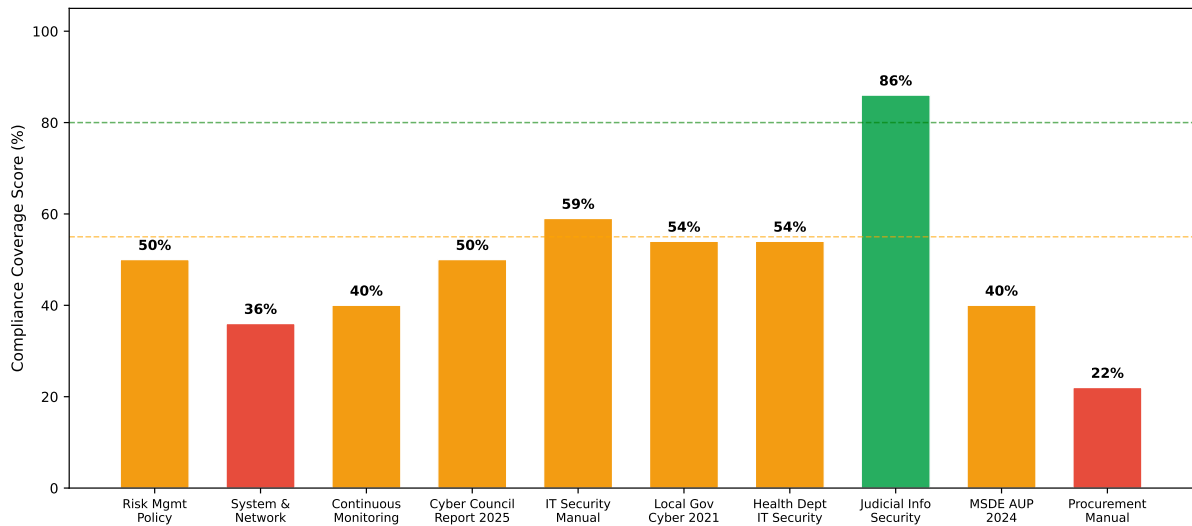


Figure 2: NIST 800-53 / FedRAMP / CMMC coverage scores for ten Maryland government policy documents. Green bars indicate LOW risk ($\geq 80\%$), orange bars MEDIUM risk (55–79%), and red bars HIGH risk ($< 55\%$). Dashed lines mark the LOW and MEDIUM risk thresholds. Source: generated by the authors from the analysis pipeline described in Section 4.1.

5.2 Control Coverage Heatmap

Figure 3 presents a control-by-document coverage heatmap, where green (“P”) cells indicate a control is present and red (“X”) cells indicate a gap. The heatmap reveals structural patterns: controls related to risk assessment (RA-01, RA-02), remote access (AC-05), network segmentation (SC-03), and personnel screening (PS-02) are widely covered, while data encryption (SC-01, SC-02) and formal account management (AC-01, AC-02) are consistently absent.

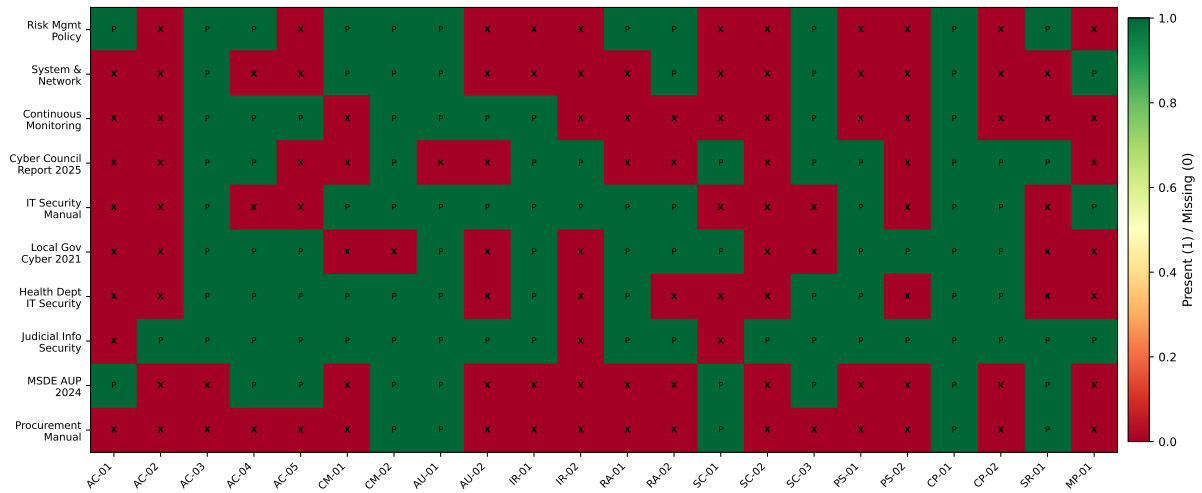


Figure 3: Per-document per-control coverage heatmap across the 22-control ProofLayer dataset. P = control present; X = control missing. Source: generated by the authors from the analysis pipeline described in Section 4.1.

5.3 Systemic Gap Analysis

Figure 4 ranks the 22 controls by their frequency of absence across the ten documents. Table 4 identifies controls missing in five or more documents.

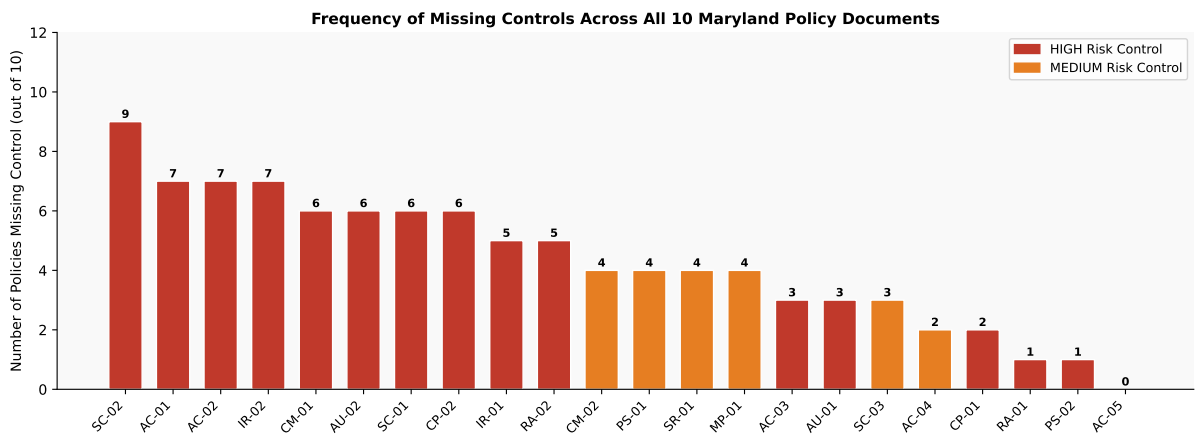


Figure 4: Frequency of missing controls across all ten Maryland policy documents, sorted by absence count. Dark red bars indicate HIGH-risk controls; orange bars indicate MEDIUM-risk controls. Source: generated by the authors from the analysis pipeline described in Section 4.1.

Table 4: Systemic HIGH-risk gaps: controls missing in five or more of the ten policy documents.

Control ID	Control Name	Missing in	Frameworks
AC-02	Account Management	9/10	FedRAMP AC-2, NIST AC-2, CMMC 3.1.1
SC-02	Data Encryption at Rest	9/10	FedRAMP SC-28, NIST SC-28, CMMC 3.13.16
AC-01	Access Control Policy	8/10	FedRAMP AC-1, NIST AC-1, CMMC AC domain ^a
IR-02	Incident Reporting	8/10	FedRAMP IR-6, NIST IR-6, CMMC 3.6.2
AU-02	Audit Review & Alerting	7/10	FedRAMP AU-6, NIST AU-6, CMMC 3.3.5
SC-01	Data Encryption in Transit	6/10	FedRAMP SC-8, NIST SC-8, CMMC 3.13.8
CM-01	Configuration Management	5/10	FedRAMP CM-1, NIST CM-1, CMMC 3.4.1
CP-02	Contingency / DR Plan	5/10	FedRAMP CP-2, NIST CP-2, CMMC 3.6.1
RA-01	Risk Assessment	5/10	FedRAMP RA-1, NIST RA-1, CMMC 3.11.1
RA-02	Vulnerability Scanning	5/10	FedRAMP RA-5, NIST RA-5, CMMC 3.11.2

^aCMMC 2.0 (based on NIST SP 800-171) does not include policy-documentation controls equivalent to NIST AC-1; the AC domain is listed as the closest applicable family.

The most striking finding is the near-universal absence of explicit encryption-at-rest controls (SC-02): only the MD Judicial Information Security Policy addresses disk encryption, AES standards, or encrypted storage in any depth. Given that ransomware attacks on Maryland agencies have involved sensitive records, this gap represents a potential policy gap for state and local government data assets.

Account management formalism (AC-02) is similarly underrepresented. While many policies discuss “access” at a conceptual level, only one of the ten contains the specific procedural language (account lifecycle, provisioning and deprovisioning procedures, or role-based onboarding workflows) needed to satisfy the NIST AC-2 control family. This finding aligns with the Maryland Cybersecurity Council’s 2021 recommendation that the state adopt centralized account management oversight through the State Chief Information Security Officer (SCISO) [2].

Incident reporting obligations (IR-02) requiring notification to CISA within specific timeframes are absent from eight of ten documents, suggesting that most Maryland agency policies have not been updated to reflect the mandatory reporting timelines established under current CISA guidance [18]. US-CERT’s functions have been incorporated into CISA since 2018, and references in policy documents to the former entity should be updated accordingly.

5.4 Cost Analysis

Figure 5 compares per-task costs between the ProofLayer multi-LLM strategy and a single gpt-4o baseline for a standard document audit.

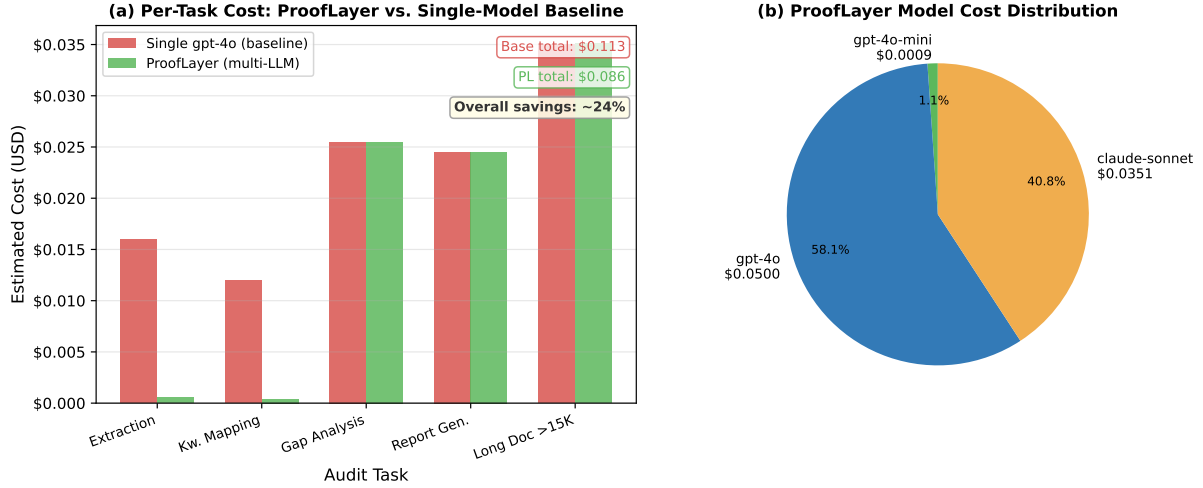


Figure 5: (a) Per-task cost comparison between single-model (gpt-4o only) and ProofLayer multi-LLM routing. (b) ProofLayer model usage distribution across a typical audit session. Source: generated by the authors from the analysis pipeline described in Section 4.1.

Table 5 quantifies the cost reduction per task. Routing document extraction and keyword mapping to gpt-4o-mini reduces costs for those tasks by approximately 97% compared to gpt-4o, since these tasks require only token-level pattern recognition rather than complex reasoning.

Gap analysis and report generation are retained on gpt-4o, as these tasks require multi-hop reasoning over long policy contexts and structured output generation. Long documents exceeding 15,000 characters are routed to claude-sonnet, which processes the full document context (~6,700 input tokens) rather than the 4,000-token window used in the single-model baseline. The lower per-token price (\$0.003/1K vs. \$0.005/1K) offsets the higher token count, yielding equivalent per-task cost with improved long-context coverage. Overall, the multi-LLM strategy achieves an estimated 24% cost reduction per audit, driven entirely by routing extraction and mapping to gpt-4o-mini, reducing the projected per-document cost from approximately \$0.113 to \$0.086.

Table 5: Per-audit cost breakdown: ProofLayer vs. single gpt-4o baseline.

Task	ProofLayer Model	Baseline	PL Cost	Base Cost	Savings
Doc. Extraction	gpt-4o-mini	gpt-4o	\$0.0005	\$0.0160	96.6%
Keyword Mapping	gpt-4o-mini	gpt-4o	\$0.0004	\$0.0120	96.6%
Gap Analysis	gpt-4o	gpt-4o	\$0.0255	\$0.0255	0.0%
Report Generation	gpt-4o	gpt-4o	\$0.0245	\$0.0245	0.0%
Long Doc (>15K) ^b	claude-sonnet	gpt-4o	\$0.0351	\$0.0350	—
Total (typical audit)			\$0.0860	\$0.1130	23.9%

^bLong-document routing directs claude-sonnet to process the full document context (~6,700 input tokens vs. ~4,000 for the gpt-4o baseline). The lower per-token cost of claude-sonnet offsets the higher token count, yielding equivalent per-task cost; the benefit of routing is improved coverage, not cost reduction.

At scale, auditing all ten Maryland policy documents in this corpus costs approximately \$0.86 under the ProofLayer strategy versus \$1.13 under single-model routing. For a state government with hundreds of agency-level policies, this translates to substantial operational savings while preserving higher-capability models for reasoning-intensive tasks.

6 Discussion

The results in Section 5 surface three interconnected themes that we examine in turn: the concrete remediation priorities implied by the identified gaps, the methodological limitations of a keyword-based Stage 1 approach, and

how ProofLayer compares to recent LLM-based compliance systems in adjacent domains. Together, these themes define the near-term improvement trajectory for ProofLayer and illuminate the broader design space for automated government compliance tools.

6.1 Implications for Maryland Policy Remediation

Our findings identify three policy areas warranting further review for Maryland state and local government cybersecurity policy improvement. First, data encryption policies should be the top remediation investment: with SC-02 missing in 9 of 10 documents, the absence of explicit encryption-at-rest requirements creates regulatory exposure across virtually every agency type examined. The Maryland DoIT should consider issuing a mandatory encryption addendum to the policy suite that explicitly requires AES-256 disk encryption and encrypted database storage for all systems handling sensitive state data.

Second, account management formalization is needed at scale. The low coverage of AC-01 and AC-02 reflects a pattern where agencies describe access control at a conceptual level in their policies but do not codify the operational procedures (formal onboarding, deprovisioning checklists, periodic access reviews) that NIST 800-53 requires. Adopting centralized account lifecycle management under the SCISO, as recommended by the 2021 Maryland Cybersecurity Council report [2], would systematically address this gap and reduce the compliance burden on individual agencies that currently maintain independent and inconsistent provisioning procedures.

Third, incident reporting procedures may require updates to align with current CISA reporting guidance [18]. Most Maryland agency policies appear to pre-date recent reporting timeline requirements; a policy update cycle triggered by automated ProofLayer audits could provide a cost-effective mechanism for keeping reporting procedures current and demonstrating compliance effort in the event of a regulatory review.

6.2 Limitations

Stage 2 is not validated, and no accuracy is claimed for it. This study evaluates only Stage 1 keyword-based mapping. The Stage 2 LLM gap analysis is implemented and specified in Section 3 but has not been compared against expert annotation, so its outputs carry no measured accuracy and should not be read as such. The cost analysis in Section 4.4 is likewise an arithmetic projection over published vendor rates, not an observed saving.

We state the protocol that would settle this, both to make the gap concrete and because the design constrains what a future result would mean. The unit of annotation is the document-control pair, giving $10 \times 22 = 220$ judgments. Each pair requires a ternary label: the control is addressed, the control is absent, or the document is out of scope for that control. Two properties matter for the result to be worth having. First, at least one annotator must be independent of the system’s authors, since an author labelling the output of their own tool cannot establish independence; agreement between two annotators should be reported as Cohen’s κ on a shared subset. Second, the labels must be fixed before the Stage 2 outputs are inspected, or the comparison measures post-hoc rationalization rather than accuracy. Language models may reasonably be used to pre-annotate and to triage which pairs need human attention, but they cannot supply the ground truth against which an LLM stage is judged, because that measures agreement among models rather than correctness.

No ground truth. The compliance scores and gap frequencies reported here are derived solely from keyword presence. Without expert annotation, precision, recall, or inter-rater agreement cannot be computed. A keyword can appear in a document in a context that does not satisfy the corresponding control (e.g., “encryption is currently unavailable”), and a policy can fully satisfy a control without using the exact terminology in the keyword dictionary. The results should be interpreted as indicators of likely gaps rather than confirmed deficiencies.

Keyword matching is not compliance verification. Keyword presence is used as a proxy for control coverage. The conclusions drawn about specific gaps reflect the output of a pattern-matching heuristic and would require expert review to confirm. Beyond false negatives and false positives in control detection, keyword matching cannot distinguish between qualitatively different implementations of the same control. For example, the SC-02 keyword set matches any occurrence of “aes” in a document but cannot differentiate between modern authenticated encryption (e.g., AES-GCM) and older cipher modes that may be vulnerable (e.g., AES-CBC without independent integrity protection). A positive SC-02 match therefore indicates mention of AES-class encryption, not necessarily a robust or compliant implementation.

Small sample and absence of confidence intervals. Ten documents represent a single pass over a convenience corpus. No hypothesis testing or bootstrap confidence intervals are reported. Results may not generalize beyond this specific corpus.

Control dataset scope. The 22-control dataset spans major NIST 800-53 families but is not exhaustive. A full FedRAMP Moderate assessment requires over 300 controls. Future work will expand the dataset and validate keyword coverage against annotated policy corpora.

Single-document analysis. Each policy document is analyzed in isolation. In practice, an agency’s posture is determined by the union of all applicable policies; a gap in one document may be addressed by another. Multi-document cross-referencing is a planned ProofLayer feature.

6.3 Comparison to Prior Approaches

ComplianceNLP [8] achieves 87.7 F1 on gap detection in the financial regulatory domain using knowledge-graph-augmented RAG. Our work is complementary: ProofLayer targets government cybersecurity policies, applies a two-stage keyword-plus-LLM pipeline, and contributes an empirical analysis of a real policy corpus. Integrating knowledge-graph-based reasoning into ProofLayer’s Stage 2 is a natural extension direction that could improve precision on borderline cases.

7 Conclusion

This paper presented ProofLayer, an AI-driven compliance auditing system that automates the assessment of government cybersecurity policy documents against standardized control frameworks (NIST 800-53, FedRAMP, CMMC). Applied to ten Maryland state and local government policy documents, ProofLayer’s keyword-based Stage 1 analysis reveals a mean compliance coverage of 49.1%, with systemic gaps in data encryption at rest (SC-02), account management (AC-01, AC-02), incident reporting (IR-02), and configuration management (CM-01). The multi-LLM orchestration strategy reduces estimated per-audit LLM cost by approximately 24% compared to single-model routing by routing extraction and keyword-mapping tasks to `gpt-4o-mini` while reserving high-capability models for gap analysis and report generation.

These results demonstrate the feasibility of automated preliminary compliance screening for resource-constrained government agencies. ProofLayer’s open-source pipeline, available at the project repository, provides a practical starting point for state CISOs seeking to systematically assess their cybersecurity policy posture. Future work will validate Stage 2 LLM gap analysis against expert-annotated ground truth, expand the control dataset to full FedRAMP Moderate coverage, integrate knowledge-graph-augmented reasoning, and develop multi-document cross-referencing to assess agency-level compliance posture across entire policy suites.

8 Funding

This research received no grant from any funding agency in the public, commercial, or not-for-profit sectors. No financial support was received for the conduct of this study or the preparation of this article.

9 Conflict of Interest

The author declares no competing financial interests. ProofLayer, the system evaluated in this study, was developed as an open-source research project with no commercial sponsor. All Maryland government policy documents used as evaluation data are publicly available under open distribution licenses. No commercial funding was received for this work, and no financial relationship exists between the author and any entity evaluated or referenced in this paper.

10 Acknowledgements

The author thanks the Maryland Department of Information Technology and the University of Maryland Global Campus for publishing the cybersecurity policy documents and council reports used in this study under open distribution licenses.

Use of AI tools. In the preparation of this work, the author used Claude (Anthropic) to assist with manuscript drafting, editing, and LaTeX formatting. After using this tool, the author reviewed and edited all content as needed and takes full responsibility for the content of the publication. No AI tool was used for data analysis, interpretation of results, or drawing of conclusions.

References

- [1] Maryland Cybersecurity Council. Maryland Cybersecurity Council Biennial Activities Report. Technical report, University of Maryland Global Campus, 2025.
- [2] Ad Hoc Committee on State and Local Cybersecurity, Maryland Cybersecurity Council. Maryland State and Local Government Cybersecurity: Analysis and Recommendations. Technical report, University of Maryland Global Campus, 2021.
- [3] Joint Task Force. Security and Privacy Controls for Information Systems and Organizations. Technical Report SP 800-53 Rev. 5, National Institute of Standards and Technology, 2020. Revision 5, includes updates as of 10 December 2020.
- [4] FedRAMP Program Management Office. FedRAMP Authorization Boundary Guidance. Technical report, U.S. General Services Administration, 2022. Rescinded and replaced by the FedRAMP Minimum Assessment Scope standard, 2025.
- [5] Office of the Under Secretary of Defense for Acquisition and Sustainment. Cybersecurity Maturity Model Certification (CMMC) Model Overview, Version 2.0. Technical report, U.S. Department of Defense, 2021. Superseded in part by the CMMC Program final rule, 32 CFR Part 170, effective 16 December 2024.
- [6] Shabnam Hassani, Mehrdad Sabetzadeh, Daniel Amyot, and Jian Liao. Rethinking legal compliance automation: Opportunities with large language models. In *Proceedings of the 32nd IEEE International Requirements Engineering Conference (RE)*, pages 432–440. IEEE, 2024.
- [7] Oh Huan Lin, Jay Yong Jun Jie, Mandy Lee Ling Siu, and Jonathan Pan. Automated post-incident policy gap analysis via threat-informed evidence mapping using large language models. *arXiv preprint arXiv:2601.03287*, 2026.
- [8] Dongxin Guo, Jikun Wu, and Siu Ming Yiu. ComplianceNLP: Knowledge-graph-augmented RAG for multi-framework regulatory gap detection. *arXiv preprint arXiv:2604.23585*, 2026.
- [9] Bimal Kumar and Dmitri Roussinov. NLP-based regulatory compliance: Using GPT-4.0 to decode regulatory documents. In *Proceedings of the Georg Nemetschek Institute Symposium on Artificial Intelligence for the Built World*, 2024.
- [10] Maryland Department of Information Technology. State Minimum Cybersecurity Standards Best Practices Guidebook. <https://doit.maryland.gov/policies/ci/Pages/state-minimum-cybersecurity-standards-best-practices-guidebook.aspx>, 2023. Accessed: June 2026.
- [11] Farzad Nourmohammadzadeh Motlagh, Mehrdad Hajizadeh, Mehryar Majd, Pejman Najafi, Feng Cheng, and Christoph Meinel. Large language models in cybersecurity: State-of-the-art. *arXiv preprint arXiv:2402.00891*, 2024.
- [12] A. Salman, S. Creese, and M. Goldsmith. Position paper: Leveraging large language models for cybersecurity compliance. In *Proceedings of the IEEE European Symposium on Security and Privacy Workshops*, pages 496–503. IEEE, 2024.
- [13] Cheng Qian et al. xRouter: Training cost-aware LLMs orchestration system via reinforcement learning. *arXiv preprint arXiv:2510.08439*, 2025.
- [14] Siddhant Kulkarni and Yukta Kulkarni. Benchmarking multi-agent LLM architectures for financial document processing: A comparative study of orchestration patterns, cost-accuracy tradeoffs and production scaling strategies. *arXiv preprint arXiv:2603.22651*, 2026.
- [15] Jeremy Singer-Vine. pdfplumber: Plumb a PDF for detailed information about each char, rectangle, line, etc. and easily extract text and tables. <https://github.com/jsvine/pdfplumber>, 2024.
- [16] ReportLab Inc. ReportLab PDF Library. <https://www.reportlab.com/>, 2024.
- [17] Devharsh Trivedi. Benchmarking municipal cybersecurity readiness through automated policy analytics: Evidence from maryland local governments. *Journal of Computing Sciences in Colleges*, 42(3), 2026. In press. Presented at the CCSC Eastern Conference 2026.
- [18] Cybersecurity and Infrastructure Security Agency. Cyber incident reporting: A unified message for reporting to the federal government. Technical report, U.S. Department of Homeland Security, March 2022.